

네트워크 공격 패킷 분석

- Port Scan 공격 패킷 분석
- Spoofing 공격 패킷 분석
- DDoS 공격 패킷 분석

1. Port scan

- 실제 공격방법을 결정하거나 공격에 이용될 수 있는 네트워크 구조, 시스템이 제공하는 서비스 등의 정보를 얻기 위해 수행되는 방법

① 서비스 확인

- 네트워크에 연결된 컴퓨터의 어떤 통로(포트)가 열려 있는지 확인하는 기술
- 어떤 서비스를 제공 중인지 파악

② 보안 취약점 탐색

- 열려 있는 포트를 통해 작동 중인 소프트웨어의 버전을 알아내고, 해당 버전에 알려진 보안 약점이 있는지 확인

③ 네트워크 구조 파악

- 방화벽이 어떤 규칙으로 포트를 막고 있는지 테스트

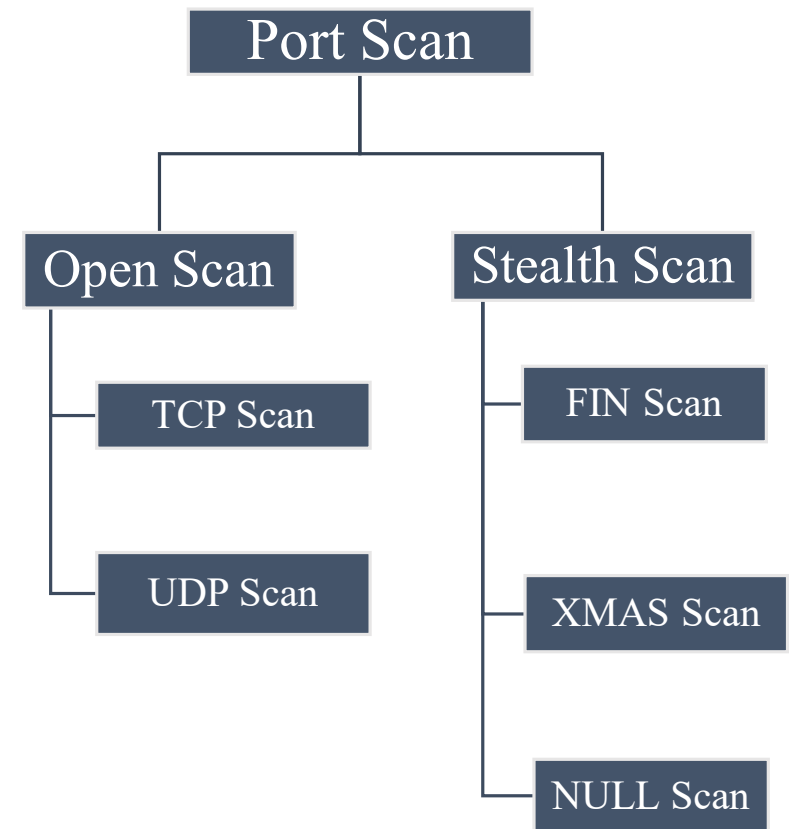
Port Scan Type

- **TCP Open Scan(TCP Connect Scan)**
 - TCP 3WHS 과정을 끝까지 완료하여 포트의 활성화 여부를 확인
 - 실제 연결이 이루어지기 때문에 대상 서버의 시스템 로그나 방화벽 로그에 기록이 남음
- **Stealth Scan**
 - 스캔하는 대상에 로그를 남기지 않고 공격 대상을 속이고 자신의 위치도 숨기는 스캔
- **Decoy Scan**
 - 공격자가 자신의 실제 IP를 숨기기 위해 여러 개의 가짜(decoy) IP를 함께 사용하여 스캔 수행
 - IDS 및 IPS의 로그 분석을 우회하기 위해 사용

nmap(network mapper)

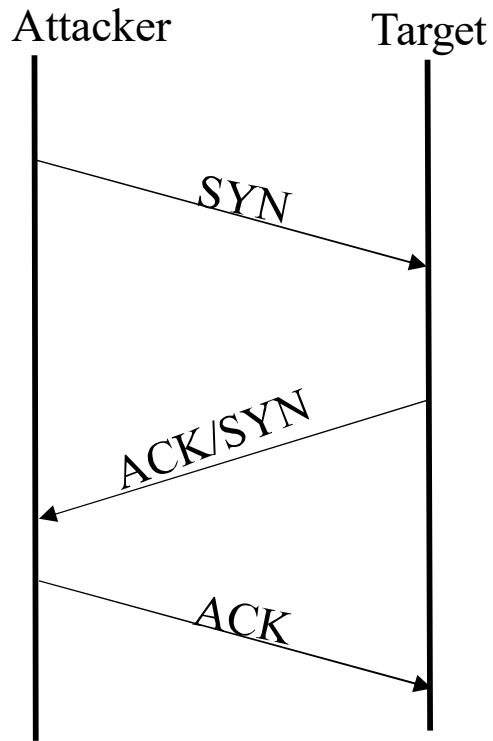
- 스캔 도구
- 운영체제 종류 및 사용 서비스에 대한 정보 스캔도구

스캔 옵션	내 용
-sT	connect() 함수를 이용한 Open 스캔
-sS	세션을 성립시키지 않는 TCP syn 스캔
-sF	Fin 패킷을 이용한 스캔
-sN	Null 패킷을 이용한 스캔
-sX	XMas 패킷을 이용한 스캔
-sU	UDP 포트 스캔
-sA	Ack 패킷에 대한 TTL 값의 분석



TCP Full Open Scan

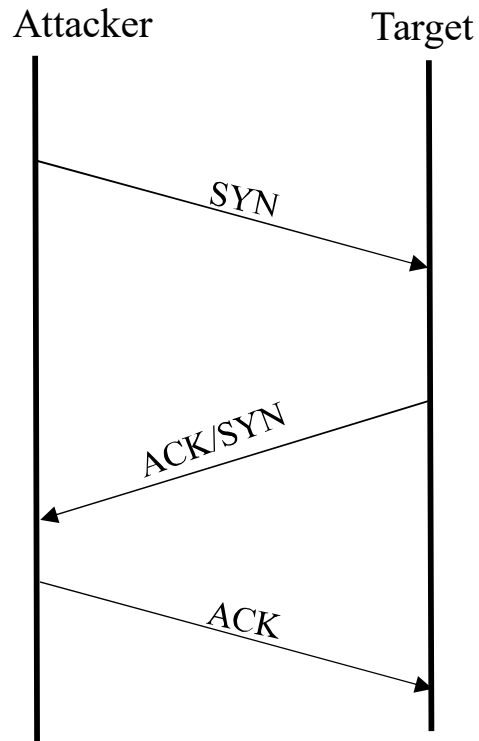
\$nmap -sT [대상IP]



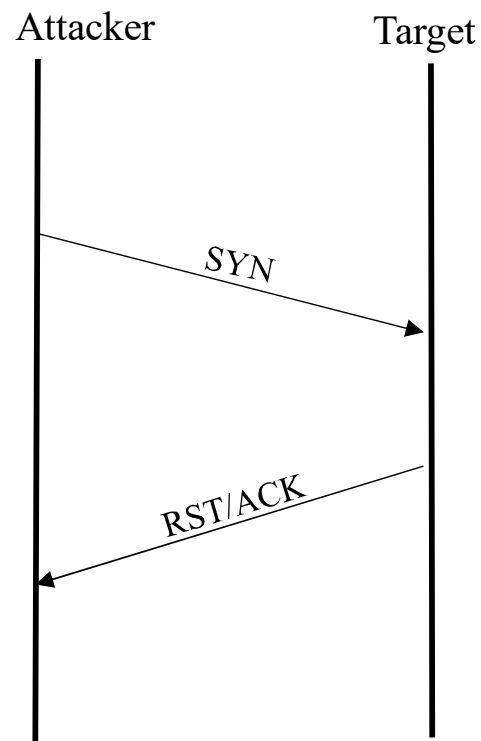
<<열린 포트인 경우 >>

- 포트가 열려 있는 경우 SYN/ACK 패킷 수신
- SYN/ACK에 ACK 패킷을 전송함으로써 연결을 완료
- 스캔하고자 하는 포트에 접속을 시도해 완전한 TCP 연결을 맺어 신뢰성 있는 결과 얻음
- 속도가 느리고 로그를 남기므로 탐지가 가능하다는 단점을 가짐

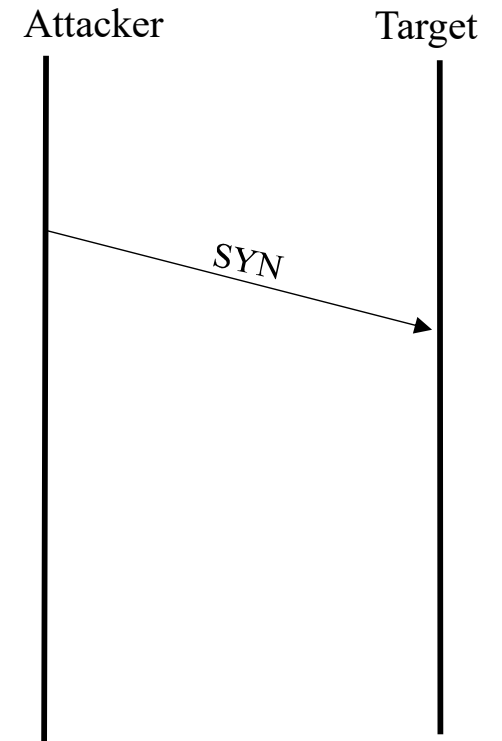
TCP Full Open Scan



<<열린 포트인 경우 >>



<<닫힌 포트인 경우 >>

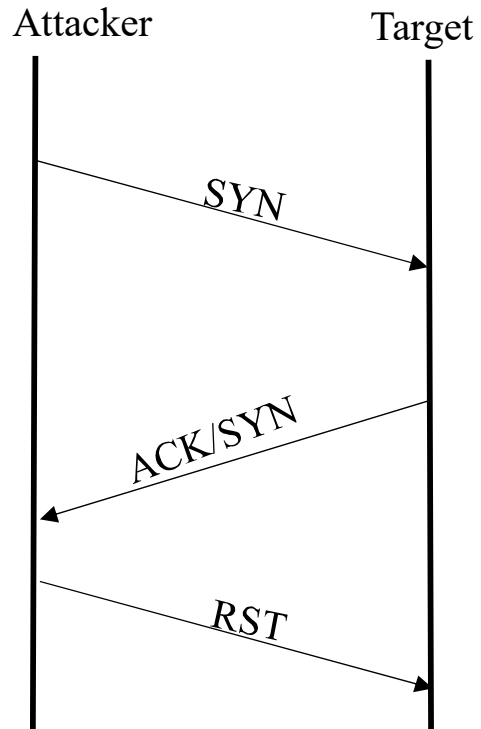


<<차단정책으로 차단되어 있는 경우>>

Stealth Scan (스텔스 스캔)

- TCP 헤더를 조작하여 특수한 패킷을 만들어 스캔 대상의 시스템에 보내어 그 응답으로 포트 활성화 여부를 알아내는 기법
- 3Way Handshaking 연결 기법을 이용한 것이 아님
- 세션을 성립하지 않고 공격 대상 시스템 포트 활성화 여부를 알아내기 때문에 공격 대상 시스템에 로그를 남기지 않음
- 시스템 관리자는 어떤 IP를 가진 공격자가 시스템을 스캔 했는지 확인 할 수 없음

TCP Half Open Scan

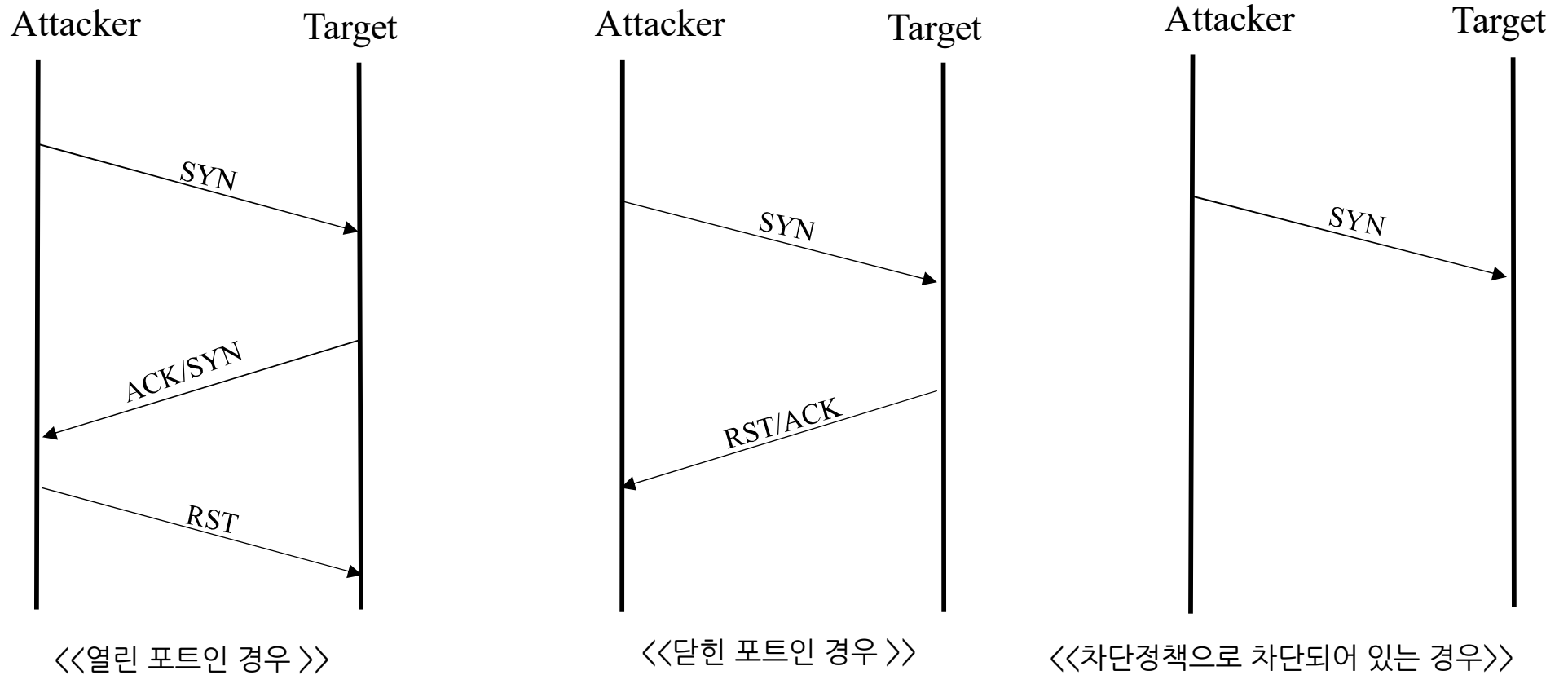


<<열린 포트인 경우 >>

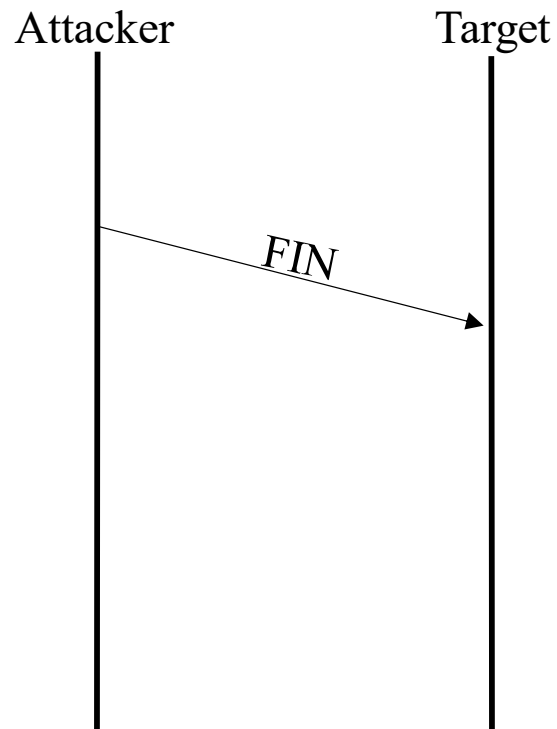
`$nmap -sS [대상IP]`

- 세션에 대한 로그가 남는 TCP Full Openscan을 보안하기 위한 기법
- 공격대상으로부터 SYN/ACK 패킷을 받으면 공격자는 RST 패킷을 보내 연결을 끊음
- 세션을 완전히 연결하지 않음
- 로그를 남기지 않아 추적이 불가능하도록 하는 기법

TCP Half Open Scan



FIN scan

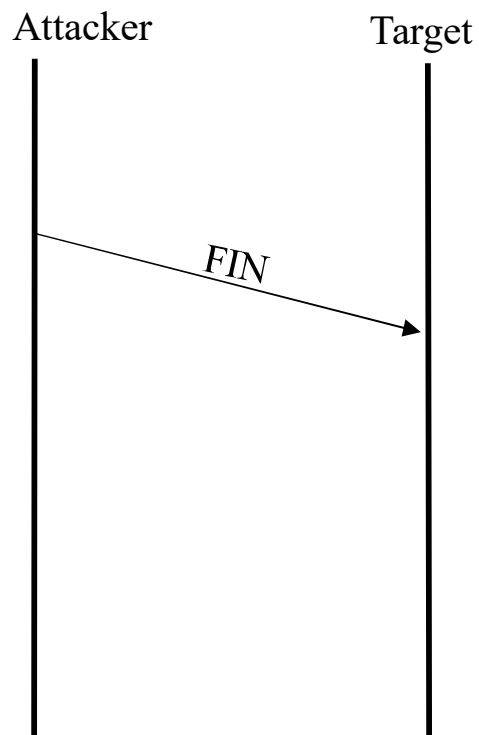


<< 열린 포트의 경우 >>

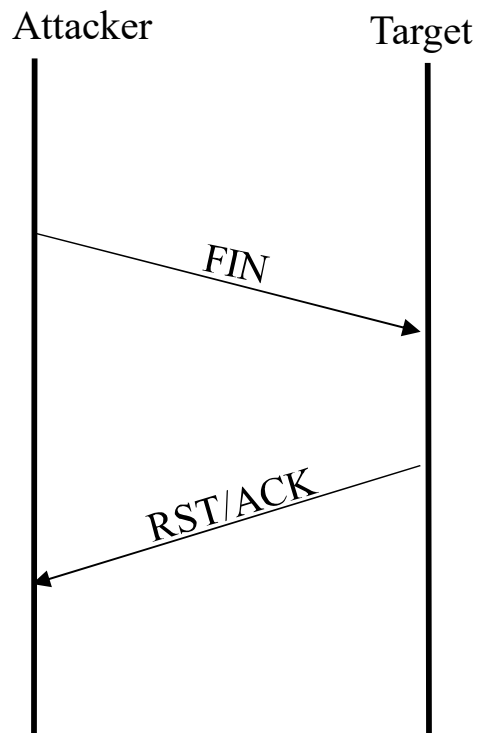
`$nmap -sF [대상IP]`

- TCP 헤더 내에서 FIN 플래그를 설정하여 공격 대상으로 메시지를 전송
- 포트가 열려 있는 경우 응답이 없음

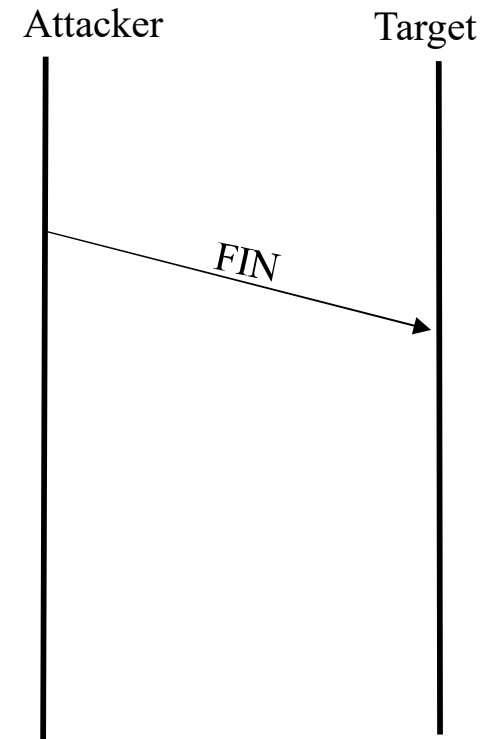
FIN scan



<< 열린 포트의 경우 >>



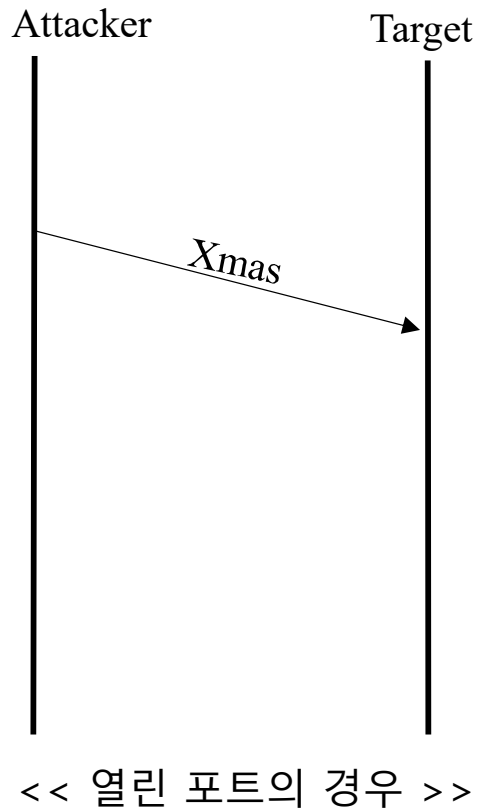
<< 닫힌 포트의 경우 >>



<< 차단정책으로 차단되어 있는 경우 >>

- *Target은 해당 포트가 Open 상태이면 Packet 무시
- *Target은 닫힌 모든 포트에 대해 RST packet을 보냄

Xmas scan



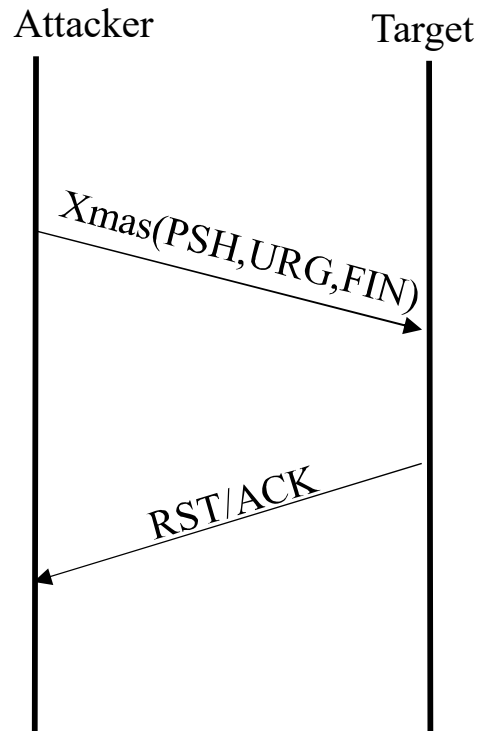
`$nmap -sX [대상IP]`

- TCP 헤더 내에서 URG, PSH, FIN을 동시에 설정해서 전송
- 포트가 열려 있는 경우 응답이 없음

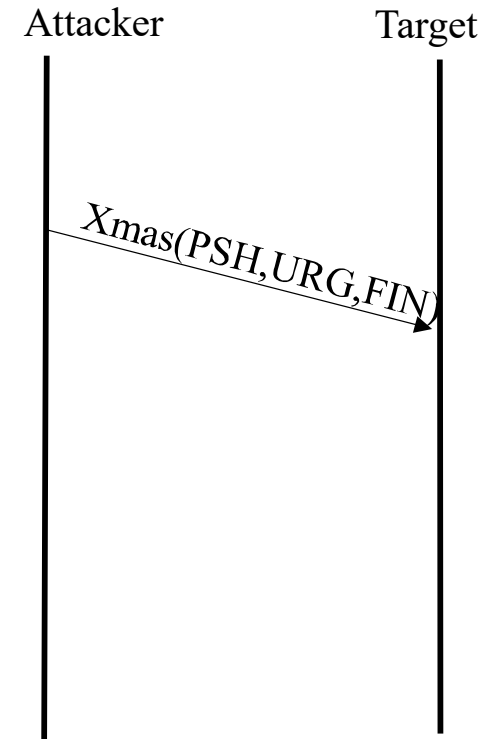
Xmas scan



<< 열린 포트의 경우 >>



<< 닫힌 포트의 경우 >>

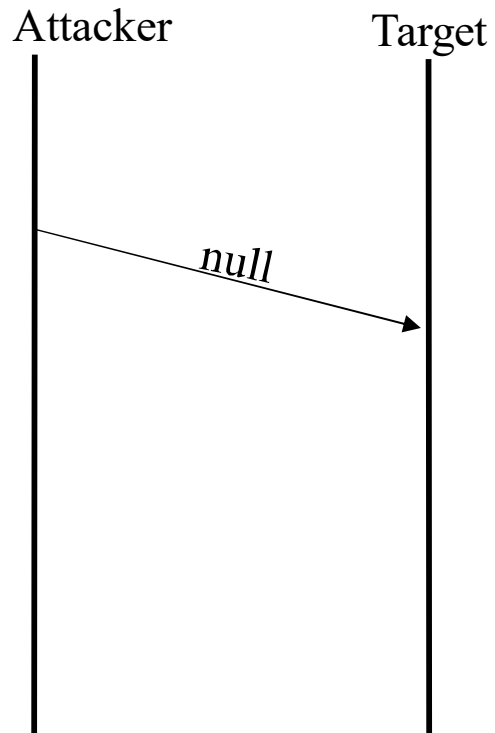


<< 차단정책으로 차단되어 있는 경우 >>

***Target은 해당 포트가 Open 상태이면 Packet 무시**

***Target은 닫힌 모든 포트에 대해 RST packet을 보냄**

Null scan

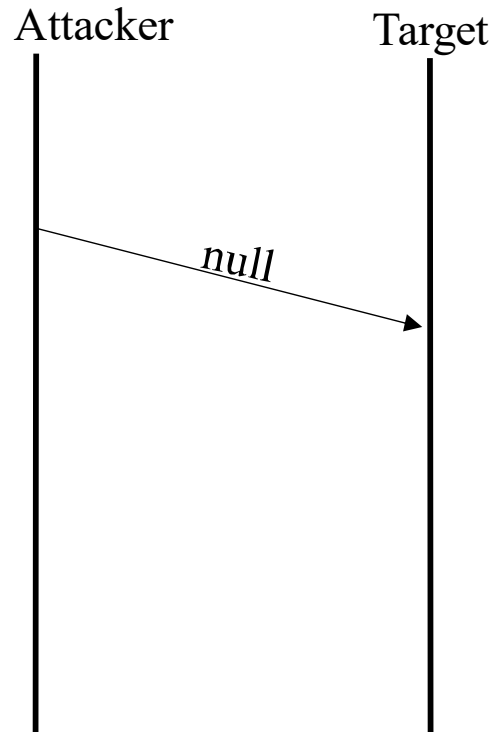


\$nmap -sN [대상IP]

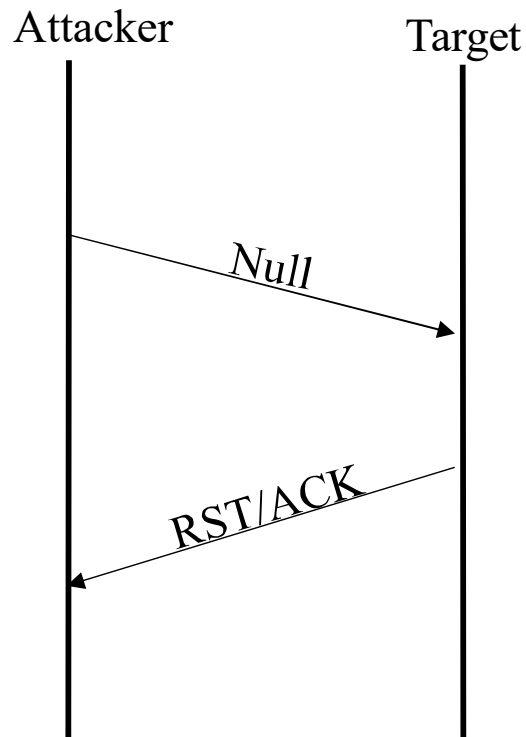
- TCP 헤더 내에 플래그 값을 설정하지 않고 패킷을 전송

<< 열린 포트의 경우 >>

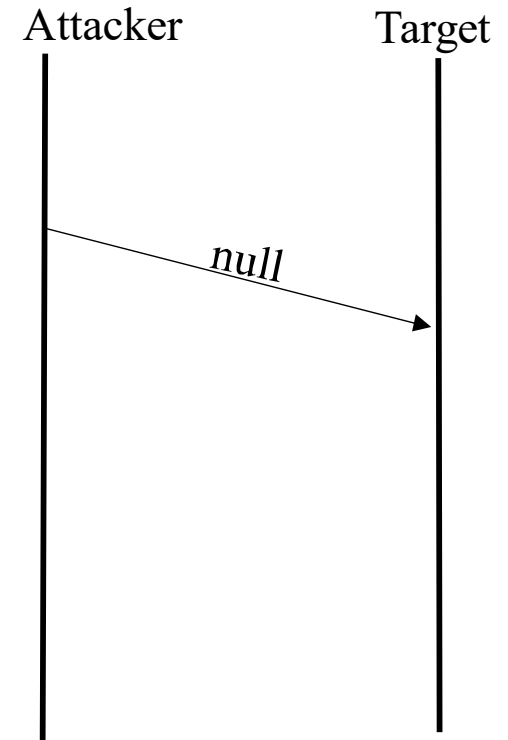
Null scan



<< 열린 포트의 경우 >>



<< 닫힌 포트의 경우 >>

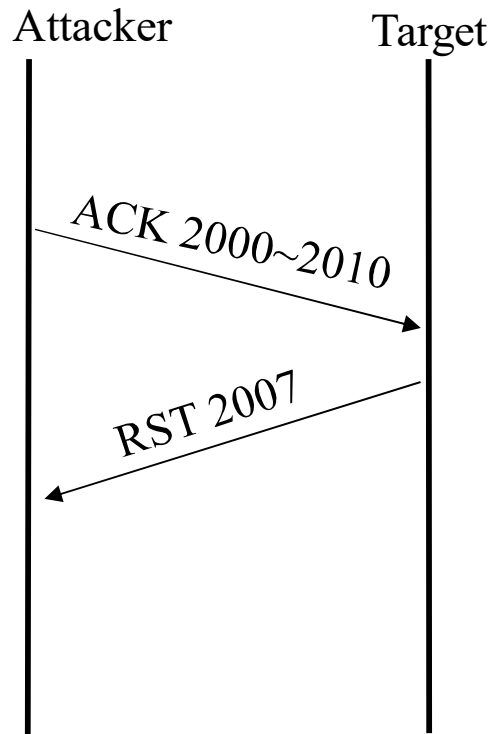


<< 차단정책으로 차단되어 있는 경우 >>

***Target은 해당 포트가 Open 상태이면 Packet 무시**

***Target은 닫힌 모든 포트에 대해 RST packet을 보냄**

TCP ACK Scan



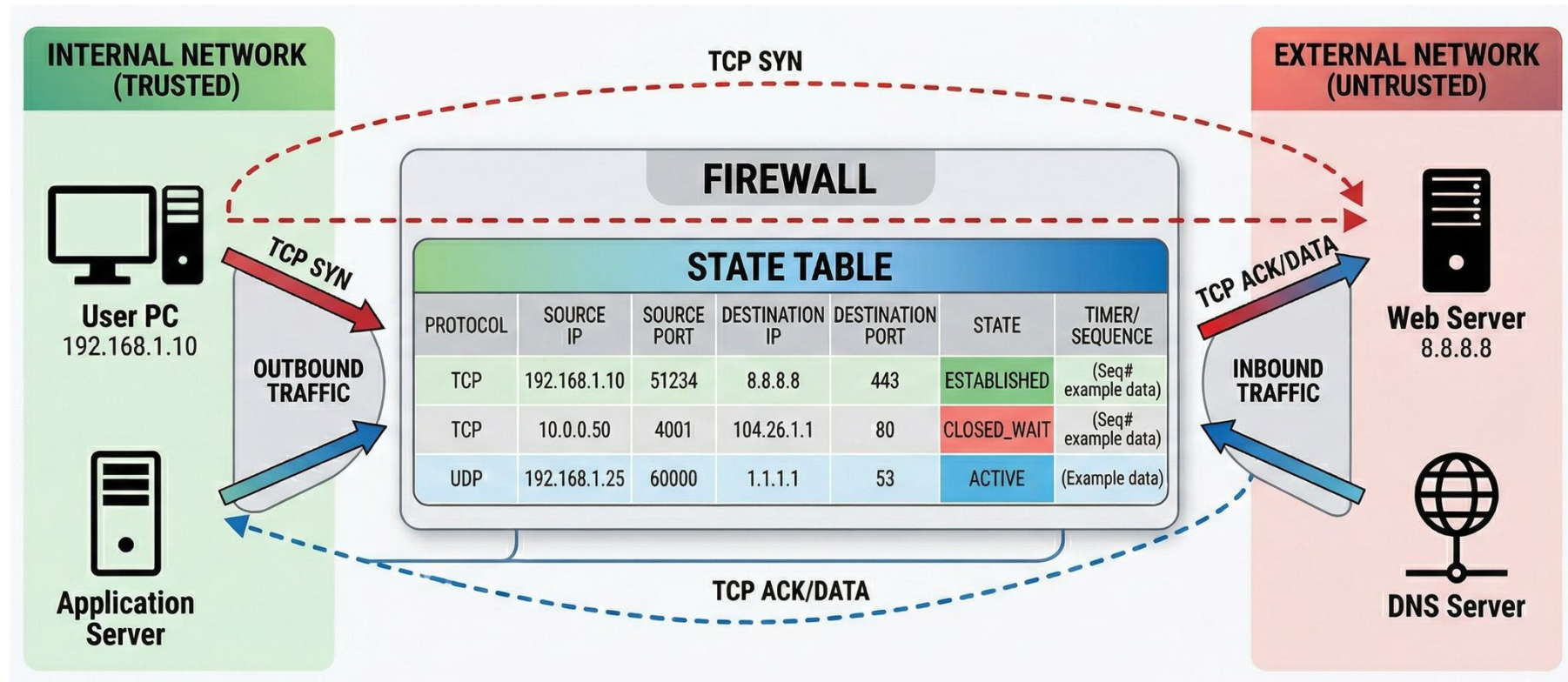
`$nmap -sA [대상IP]`

- 방화벽의 정책을 설계하는 데 사용
- 대상 포트가 열려 있는지 확인하는 용도보다는, 주로 방화벽의 필터링 규칙을 파악
 - 보안 장비의 필터링 수행 여부 판별하기 위한 목적
- 방화벽이 상태 보존형(Stateful)인지 아닌지를 판별하기 위해 사용

<< 방화벽 허용 포트 2007 >>

상태 테이블 (State Table)

- 출발지 IP, 목적지 IP, 포트 번호, TCP 시퀀스 번호 등의 정보를 기록

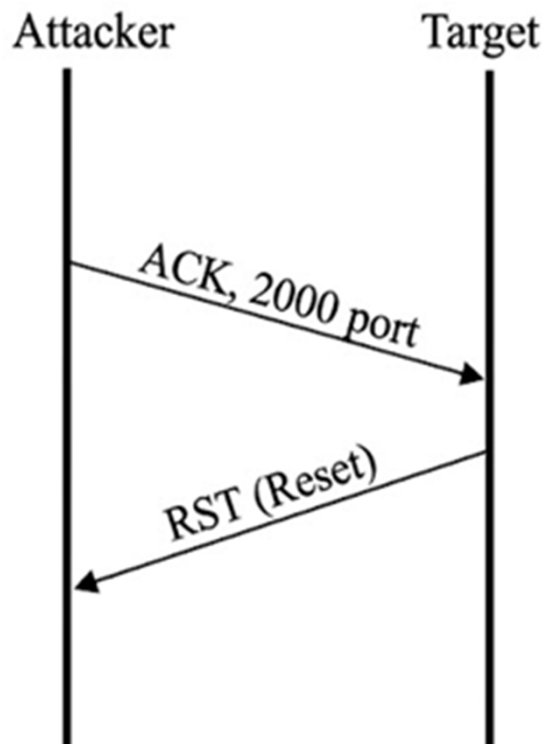


- **상태 보존형 방화벽인 경우:** 요청(Outbound)이 나갈 때 기록을 해 두었다가, 돌아오는 응답(Inbound) 패킷이 오면 테이블을 확인해 자동으로 통과시킴
- **상태 비보존형(Stateless/Packet Filtering) 방화벽인 경우:** Outbound과 Inbound 패킷에 대한 규칙을 각각 일일이 만들어줘야 함

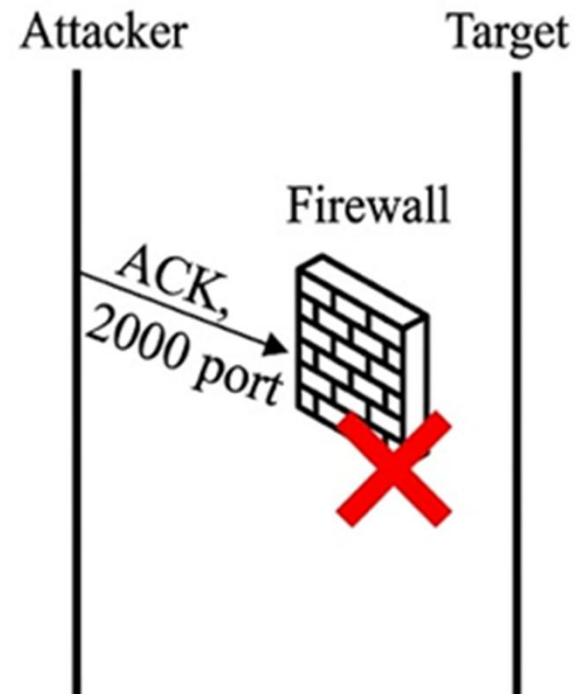
TCP ACK Scan

응답 결과	판단 (Nmap 기준)	의미
RST (Reset)	Unfiltered (비필터링)	패킷이 방화벽을 통과해 대상 OS까지 도달함 OS는 세션을 맺은 적이 없으므로 ACK를 받았으므로 연결을 끊으라는 RST를 보냄 포트의 오픈 여부는 알 수 없음
응답 없음 (Drop)	Filtered (필터링)	방화벽이 중간에서 패킷을 차단함.
ICMP 에러	Filtered (필터링)	방화벽이 명시적으로 패킷을 거부함 (Type 3, Code 13 등) Type 3 : Destination Unreachable Code 13 : Administratively Prohibited

TCP ACK Scan



<< 방화벽에 차단정책(필터링)을 적용하지 않은 경우 : Unfiltered >>



<< 방화벽이 차단정책(필터링)을 적용한 경우: Filtered >>
- 응답이 없거나 ICMP 메시지 출력

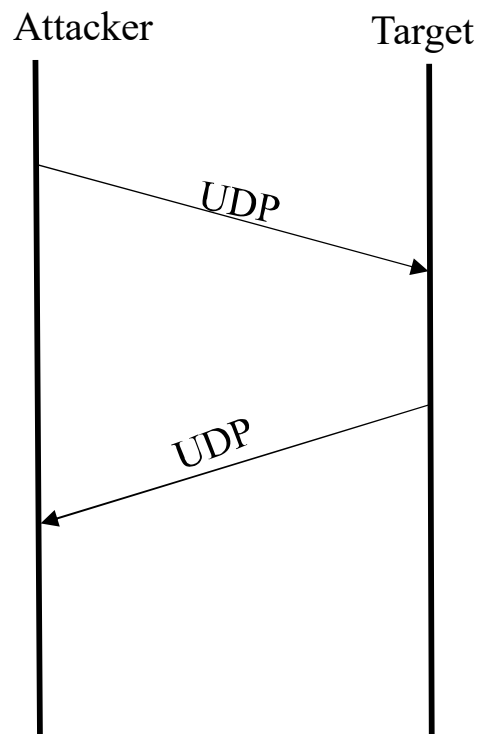
- * ACK 스캔은 포트가 Open인지 Closed인지 구분하지 못함
- * 둘 다 똑같이 RST를 보내기 때문
- * 오직 방화벽 통과 여부만 확인 가능

UDP Scan

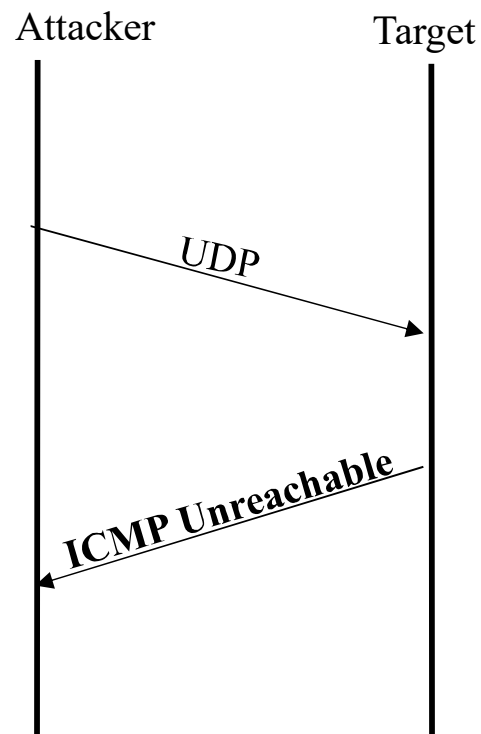
- UDP는 3-way handshake 와 같은 절차가 없음
- UDP 패킷을 전송 시 열려 있는 포트로부터 특정 UDP 응답값으로 수신
- 수신측의 포트가 닫혀 있는 경우 ICMP Port Unreachable 에러 메시지를 통해 포트 활성화 유무 확인

`$nmap -sU [대상서버IP]`

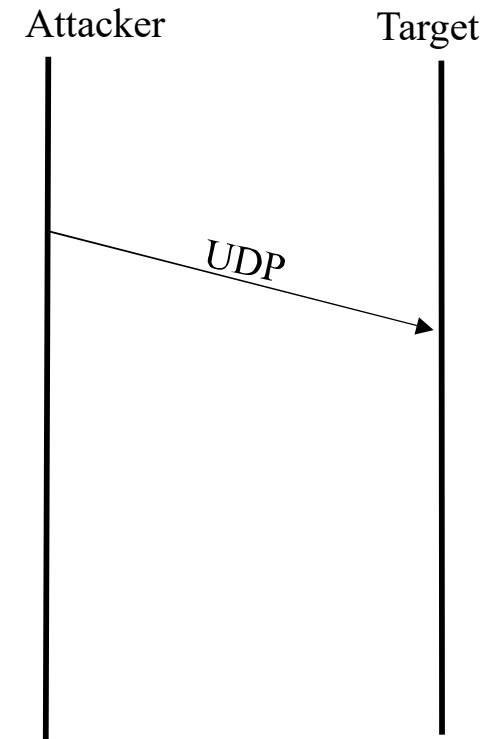
UDP Scan



<<열린 포트인 경우 >>



<<닫힌 포트인 경우 >>



<<차단정책으로 차단되어 있는 경우>>

2. Spoofing 공격

- ‘속이다’라는 뜻
- 공격자가 자신의 식별 정보를 타인의 것이나 신뢰할 수 있는 정보로 위장하여 네트워크 침투, 데이터 탈취, 서비스 방해를 수행하는 공격 기법
- 공격 종류
 - ARP 스푸핑 (ARP Spoofing)
 - IP 스푸핑 (IP Spoofing)
 - DNS 스푸핑 (DNS Spoofing / DNS Cache Poisoning)
 - 이메일 스푸핑 (Email Spoofing)

공격 유형	타겟 계층	식별 정보	공격기법
ARP Spoofing	2계층	MAC 주소	공격자가 특정 IP의 MAC 주소가 자신의 것인 양 허위 ARP Reply 패킷을 전송
IP Spoofing	3계층	IP 주소	- IP 인증 우회 - 특정 IP만 접속 가능한 서버에 침투 시 사용 - 패킷 헤더의 발신지 IP를 조작 - 공격자가 전송하는 패킷의 소스 IP 주소를 신뢰받는 호스트의 IP 주소로 변조하는 기법
DNS Spoofing	응용 계층	도메인 /IP 매핑	사용자가 특정 도메인을 요청했을 때, 실제 DNS 서버보다 빨리 조작된 응답을 보내어 공격자의 서버로 접속하게 만듦
이메일 Spoofing	응용 계층	이메일 헤더	- 이메일의 발신자 주소를 신뢰할 수 있는 사람이거나 기관으로 위조하는 방식 - 발신자의 진위 여부를 강력하게 검증하지 않는다는 점을 악용

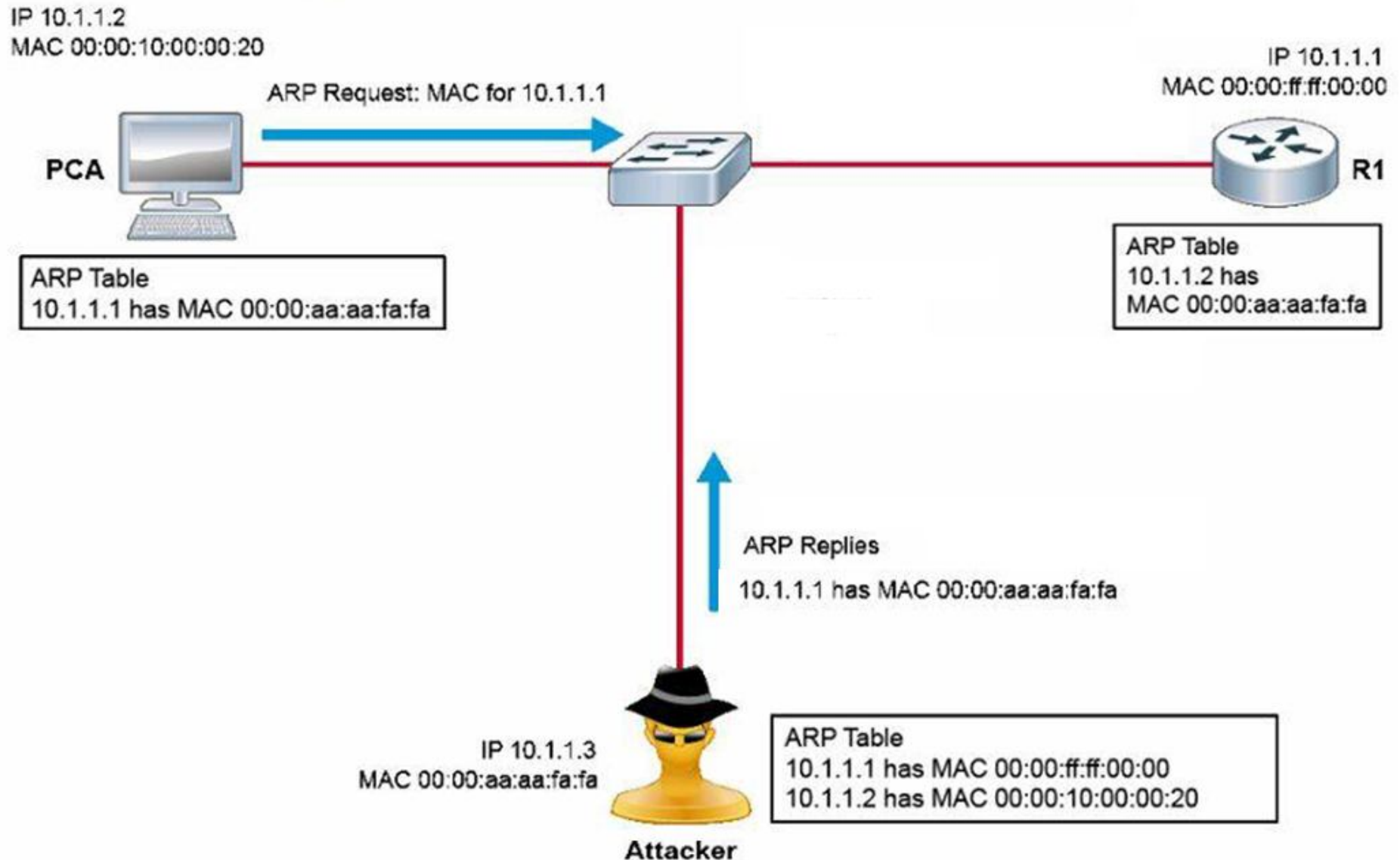
ARP Spoofing

- 공격자가 특정 호스트의 MAC 주소를 자신의 MAC 주소로 위조한 ARP Reply 패킷을 만들어 희생자에게 지속적으로 전송
- 희생자의 ARP Cache에 특정 호스트의 MAC 정보가 공격자의 MAC 정보로 변경
- 희생자로부터 특정 호스트로 나가는 패킷을 공격자가 스니핑

ARP Redirect

- ARP reply패킷을 해당 네트워크에 브로드캐스트 하여 해당 네트워크의 공격자가 자신이 라우터인것 처럼 MAC 주소를 위조하여 모든 호스트와 라우터 사이의 트래픽을 스니핑
- 호스트와 라우터 사이의 트래픽을 스니핑
- IP forward 기능을 통해 사용자들이 눈치채지 못하도록 하는 기법

ARP Redirect Attack



DNS Spoofing(DNS Cache Poisoning)

- DNS 서버는 성능 향상을 위해 캐시 정보를 사용하여 응답
- 상위 DNS로의 반복적인 질의를 줄이기 위해 응답 서버를 캐시에 일정시간 유지
- [공격기법]

단계1. 공격자는 조작된 도메인 질의 응답 메시지를 희생자 DNS에 다량으로 전송

- 이때 Transaction ID를 모르기 때문에 랜덤하게 다수의 응답 메시지를 생성

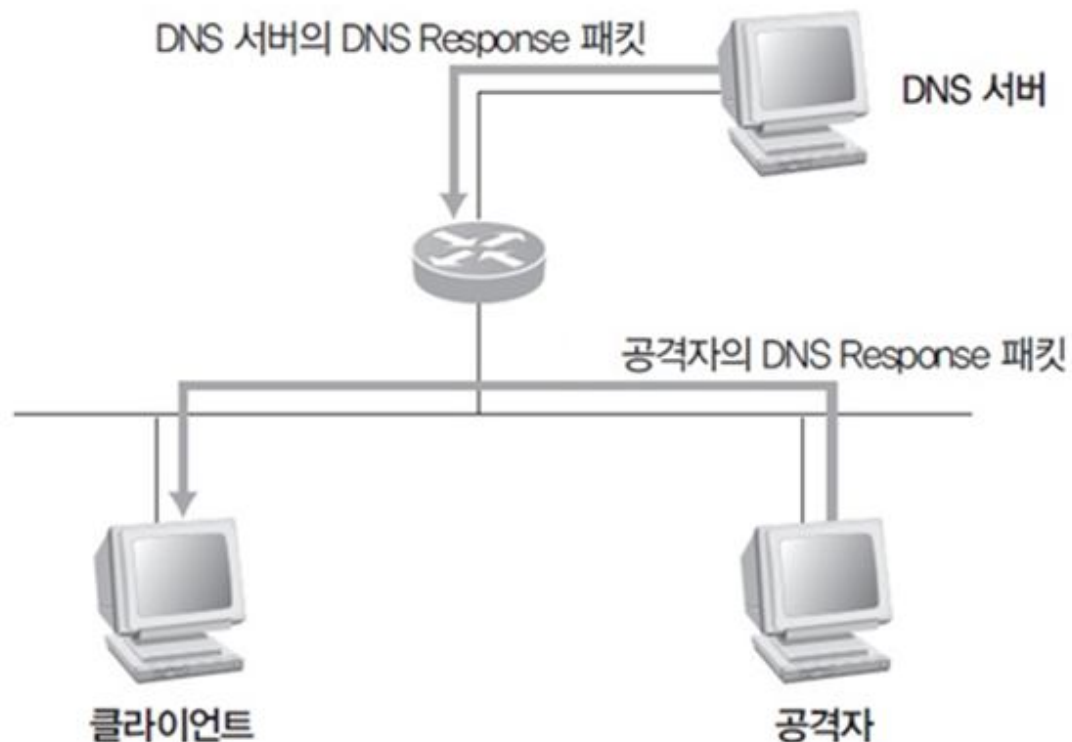
단계2. 조작된 응답 중 정상응답보다 먼저 일치되는 응답이 있으면 캐시에 저장

DNS Reply를 수락하는 조건

- DNS 응답 메시지를 자신의 캐시에 저장하려면, 다음 정보가 일치해야 함
 - 질의한 도메인 네임
 - Source Port Number
 - Transaction ID (TXID)

DNS Spoofing(DNS Cache Poisoning)

- DNS 서버의 캐시 정보를 조작하여 사용자를 가짜 사이트로 유도하는 공격
- 실제 DNS 서버보다 빠르게 위조된 DNS response 패킷을 보내 공격 대상이 잘못된 IP 주소로 웹 접속을 하도록 만드는 공격 방법
- 클라이언트는 이미 DNS response를 받았으므로 정상 DNS response는 drop

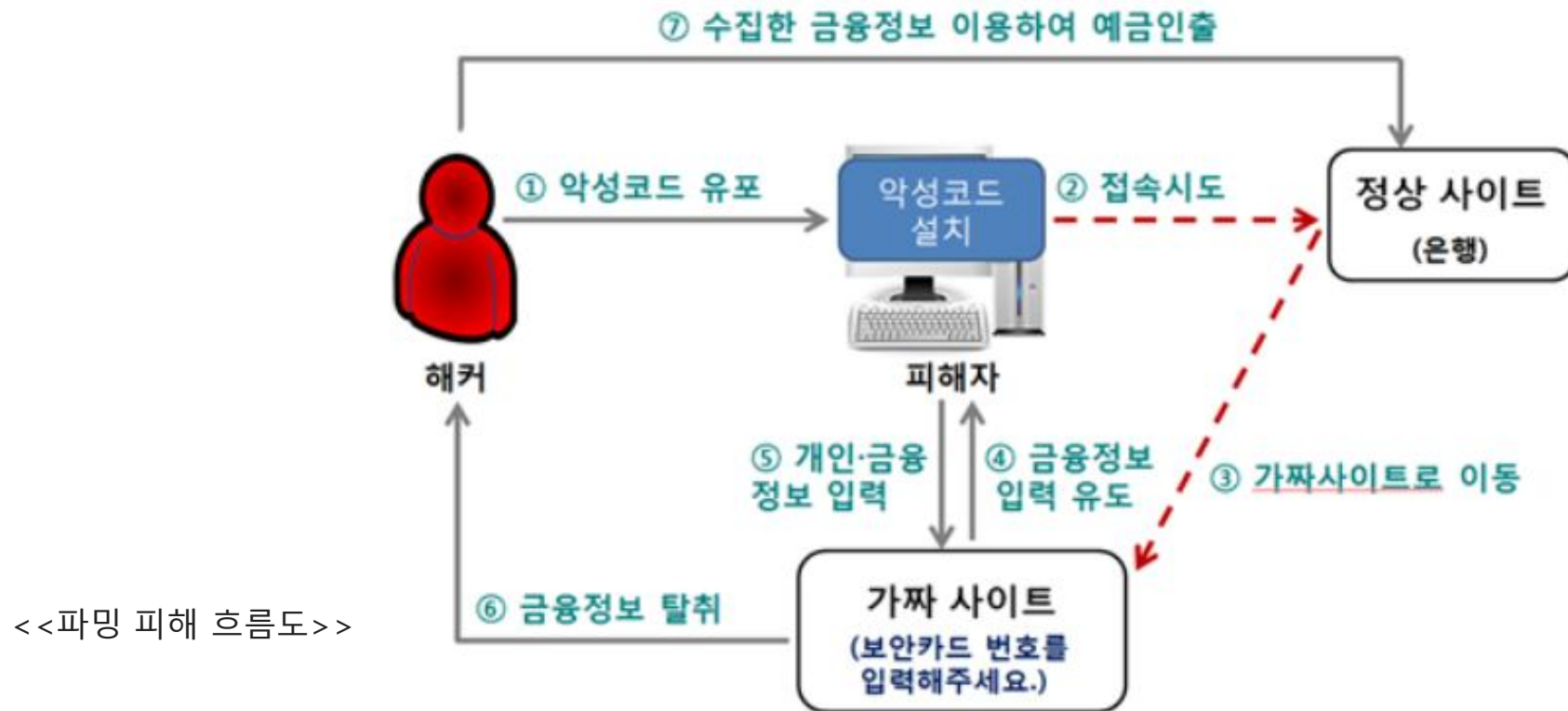


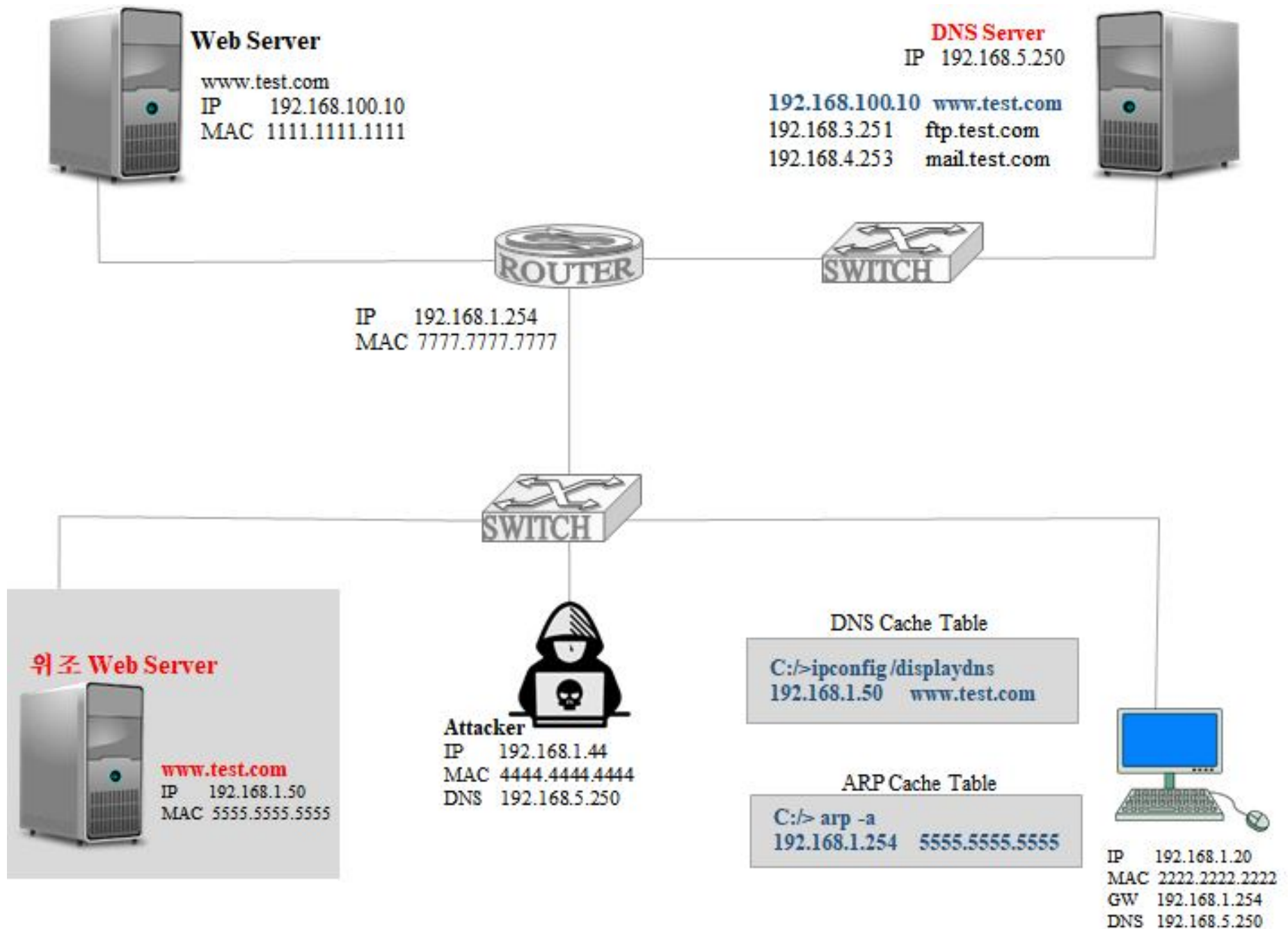
3. Sniffing 공격

- 네트워크상에서 통과하는 패킷들을 엿보며 정보를 가로채는 행위
- 네트워크의 트래픽을 몰래 감시하고 분석하는 공격 기법
- 공격 종류
 - 스위치 재밍(jamming, MAC flooding)
 - ICMP redirect
 - Spoofing 기술을 이용한 sniffing : ARP Spoofing, DNS Spoofing

4. Pharming Attack

- 피싱(Phishing)+ 조작(Farming)의 합성어
- 정상 사이트에 접속하더라도 가짜 사이트로 접속을 유도하여 금융거래정보를 빼낸 후 금전적인 피해를 입히는 사기 수법





ARP Redirect Attack

```
#arp spoof -i eth0 -t 192.168.10.40 192.168.10.2
```

```
(root@kali)-[/]  
# ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.10.10 netmask 255.255.255.0 broadcast 192.168.10.255  
    inet6 fe80::32a8:b96:c197:1e6e prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:bc:ad:00 txqueuelen 1000 (Ethernet)  
    RX packets 2675 bytes 252128 (246.2 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 8961 bytes 608042 (593.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

<<공격 전>>

인터페이스: 192.168.10.40 --- 0xe	인터넷 주소	물리적 주소	유형
192.168.10.2	00-50-56-e5-76-78	정상적	
192.168.10.10	00-0c-29-bc-ad-00	정상적	
192.168.10.255	ff-ff-ff-ff-ff-ff	정상적	
224.0.0.22	01-00-5e-00-00-16	정상적	
224.0.0.251	01-00-5e-00-00-fb	정상적	
224.0.0.252	01-00-5e-00-00-fc	정상적	
239.255.255.250	01-00-5e-7f-ff-fa	정상적	

<<공격 후>>

인터페이스: 192.168.10.40 --- 0xe	인터넷 주소	물리적 주소	유형
192.168.10.2	00-0c-29-bc-ad-00	정상적	
192.168.10.10	00-0c-29-bc-ad-00	정상적	
192.168.10.255	ff-ff-ff-ff-ff-ff	정상적	
224.0.0.22	01-00-5e-00-00-16	정상적	
224.0.0.251	01-00-5e-00-00-fb	정상적	
224.0.0.252	01-00-5e-00-00-fc	정상적	
239.255.255.250	01-00-5e-7f-ff-fa	정상적	

DNS Spoofing

<<DNS Table 생성 >>

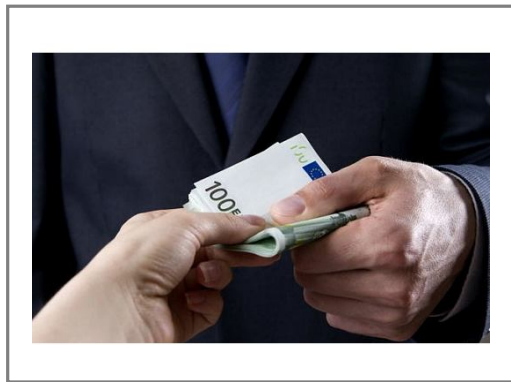
```
#cd /  
#vi dns  
192.168.10.10 www.sks.com  
:wq!
```

<<DSN Spoofing 수행 >>

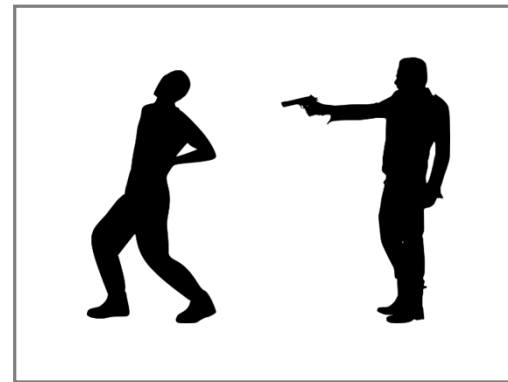
```
#dnsspoof -f /dns  
DNS table 파일이름
```


5. 서비스 거부 공격(DoS, Denial of Service)

- 공격 대상의 자원을 고의적으로 고갈시켜, 정상적인 사용자가 서비스를 이용하지 못하게 만드는 공격(가용성 파괴)
- 과도한 트래픽 또는 부하를 발생시켜 정상적인 통신이 불가능하게 만드는 통신 유형
- 공격 목적



금전요구



개인적 원한



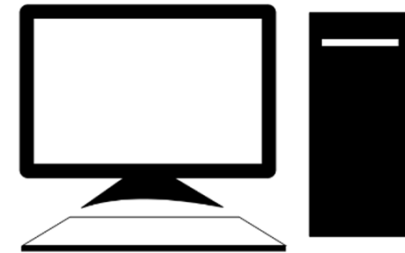
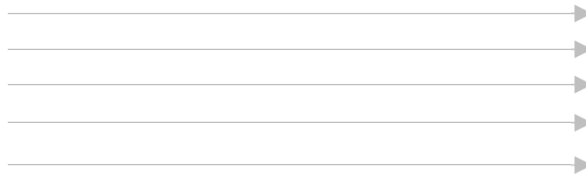
경쟁상에 의한 공격/청부



해티비즘

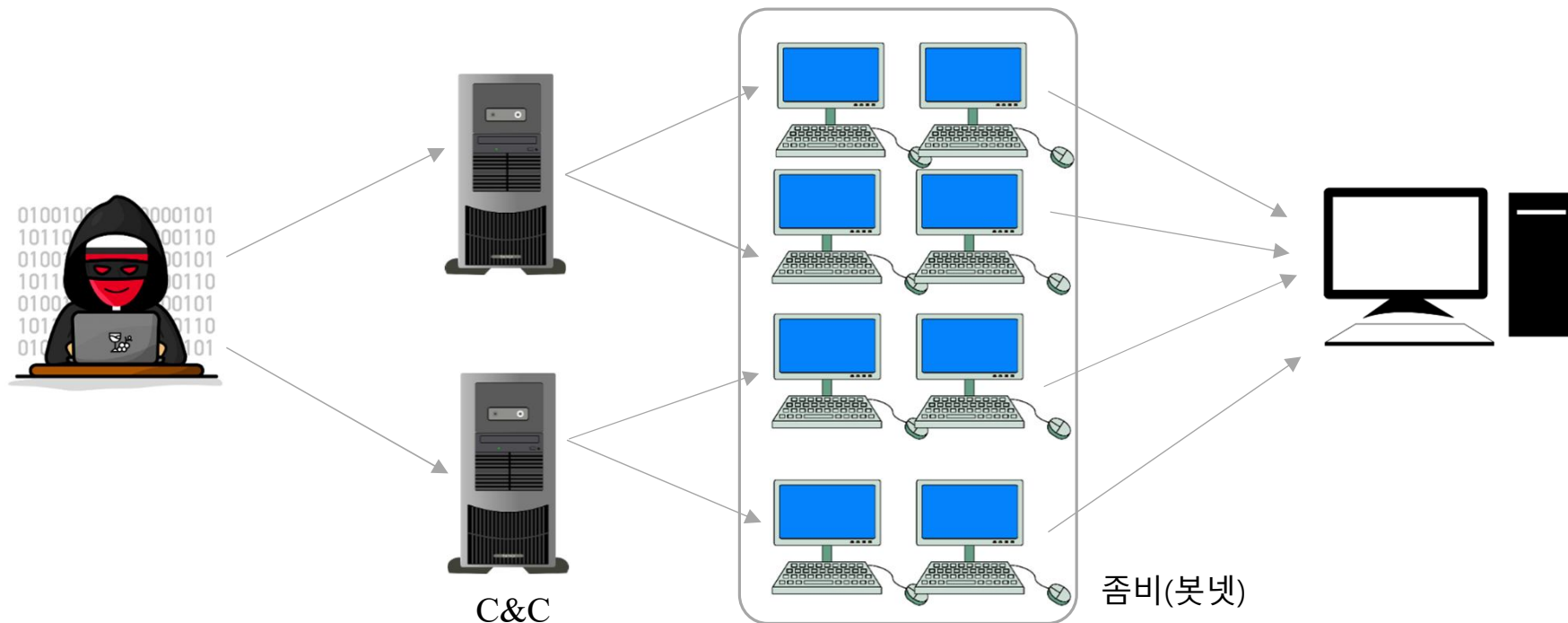
DoS (Denial of Service, 서비스 거부 공격)

- 특정 공격 PC 또는 서버 1대에서 공격 대상 서버 1대로 과도한 트래픽 또는 패킷은 전송하는 1:1 형태



DDoS (Distributed Denial of Service, 분산서비스거부공격)

- 서버와 차단 장비의 성능이 높아짐에 따라 DoS와 같은 1:1 공격은 더 큰 효과를 낼 수 없게 되었음
- 공격 성능을 증대 시키기 위해 탄생한 것
- 악성코드에 감염된 여러 대의 좀비들을 이용하여 동시에 공격하므로 N:1 형태를 띠

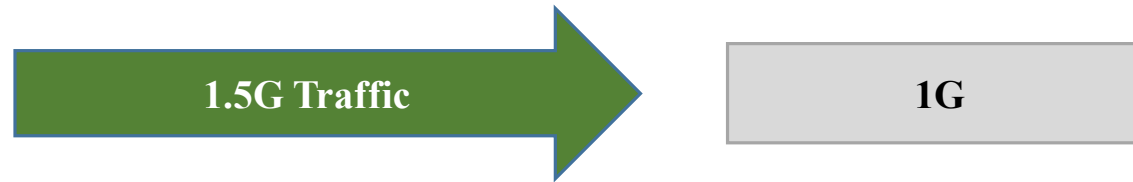


서비스 거부 공격 유형

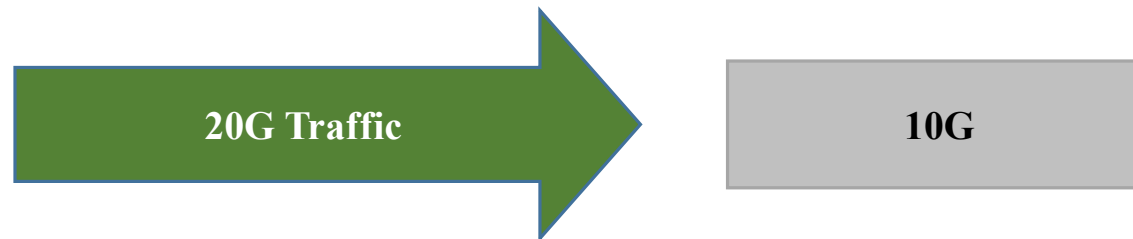
네트워크 대역폭 고갈	네트워크 통로 자체를 막아버리는 공격방식 ICMP Flood (Smurf Attack), UDP Flood
서버 자원 고갈	서버의 커넥션 정보나 CPU/메모리 처리 능력을 소모 시킴 Ping of Death, SYN Flood, Teardrop
서버 자원 고갈형 공격	웹 서버나 DB 같은 특정 애플리케이션의 로직을 공략 HTTP GET Flood Slowloris (Slow HTTP Header Dos) Cache Control(CC) Attack Hulk DoS

네트워크 대역폭 고갈

- 전송 매체 별 **자신이 수용 가능한 대역폭 이상의 트래픽 전송 이 전송될 경우**, 전송된 트래픽을 수용하지 못하여 정상적인 통신이 불가능해짐
- 네트워크 통로 자체를 막아버리는 공격방식



UTP Cable(1G)

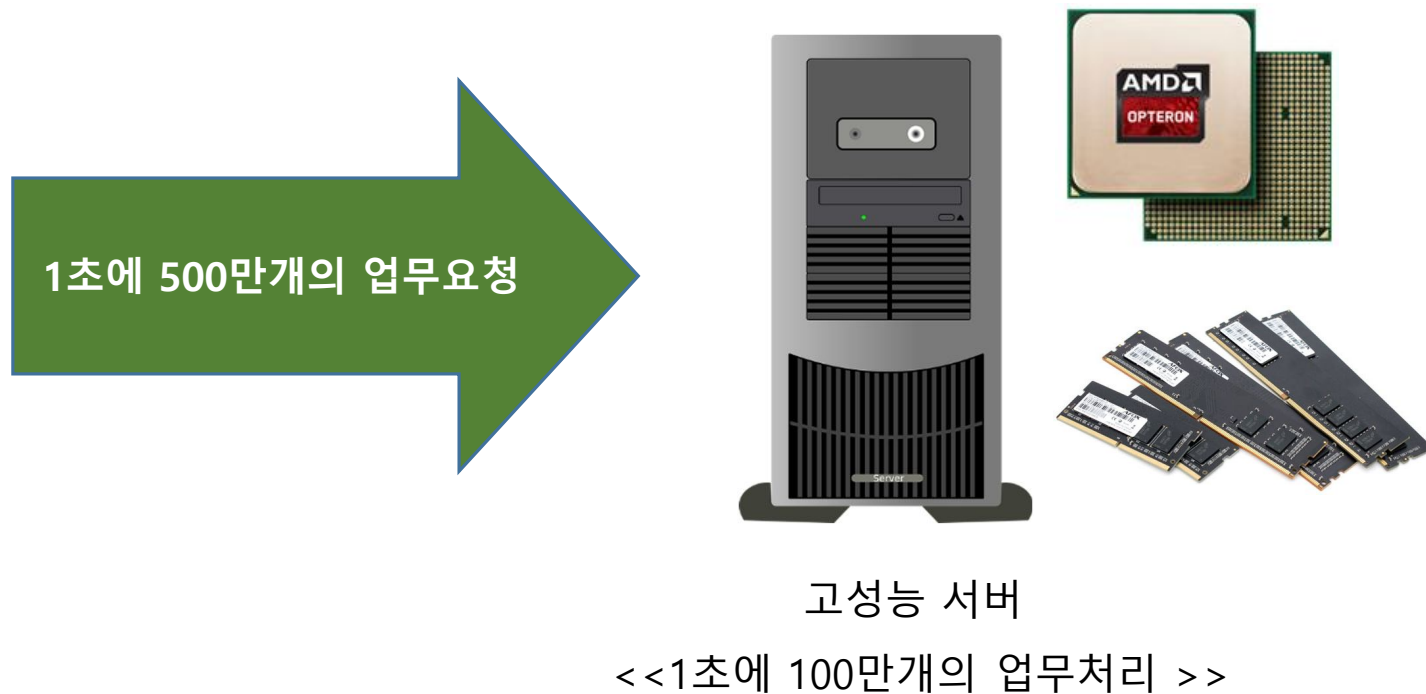


Optical Cable(10G)

공격 예) ICMP Flood (Smurf Attack), UDP Flood 등

시스템 자원 고갈 공격

- 각 정보원이 **처리 가능한 성능 이상의 요청이 발생할 경우** 이를 처리하지 못하여 정상적인 통신이 불가능해짐



(공격 예) SYN Flooding, Ping of death 등

응용 서비스 고갈 (HTTP/Application 계열)

- 웹 서버나 DB 같은 특정 애플리케이션의 로직을 이용한 공격

(공격예) HTTP GET Flood, Slowloris (Slow HTTP Header Dos)

Cache Control(CC) Attack, Hulk DoS

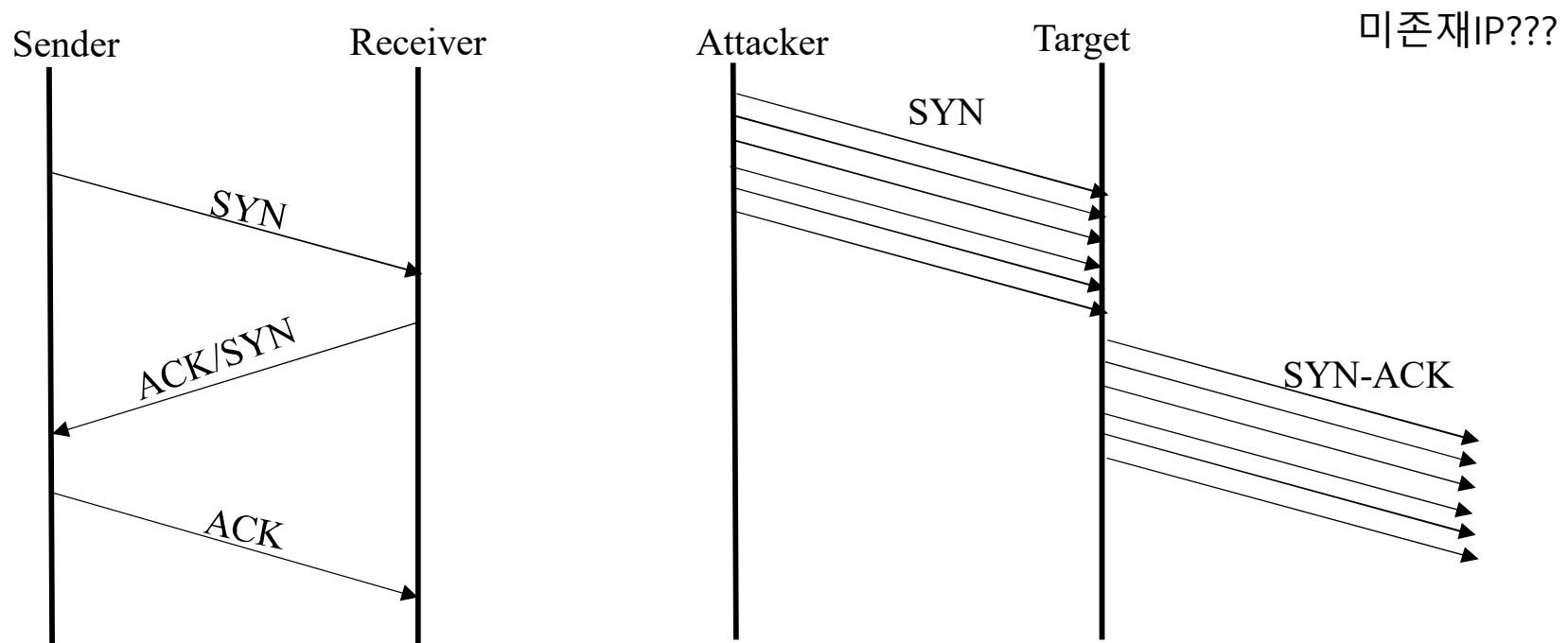
TCP SYN Flooding Attack

- TCP이 3-way-handshake 과정에서 발생 가능한 취약점을 이용한 공격 유형
- 송신지 IP 를 존재하지 않는 IP주소로 위조하여 대량의 SYN Packet을 발송
 - 해당 시스템의 백로그(backlog) 큐(queue)를 가득 채워 서비스 거부하도록 유도
- 서비스를 제공하는 시스템은 수용할 수 있는 수가 제한
 - 한정되어 있는 연결을 모두 사용하여 다른 사람이 사용하지 못하게 하는 공격

TCP SYN Flooding Attack

- SYN Flooding 공격을 이용하여 Web Server의 HTTP 서비스를 지연 또는 정지시킴
* 10초 내에 패킷 50여만개의 SYN 전송

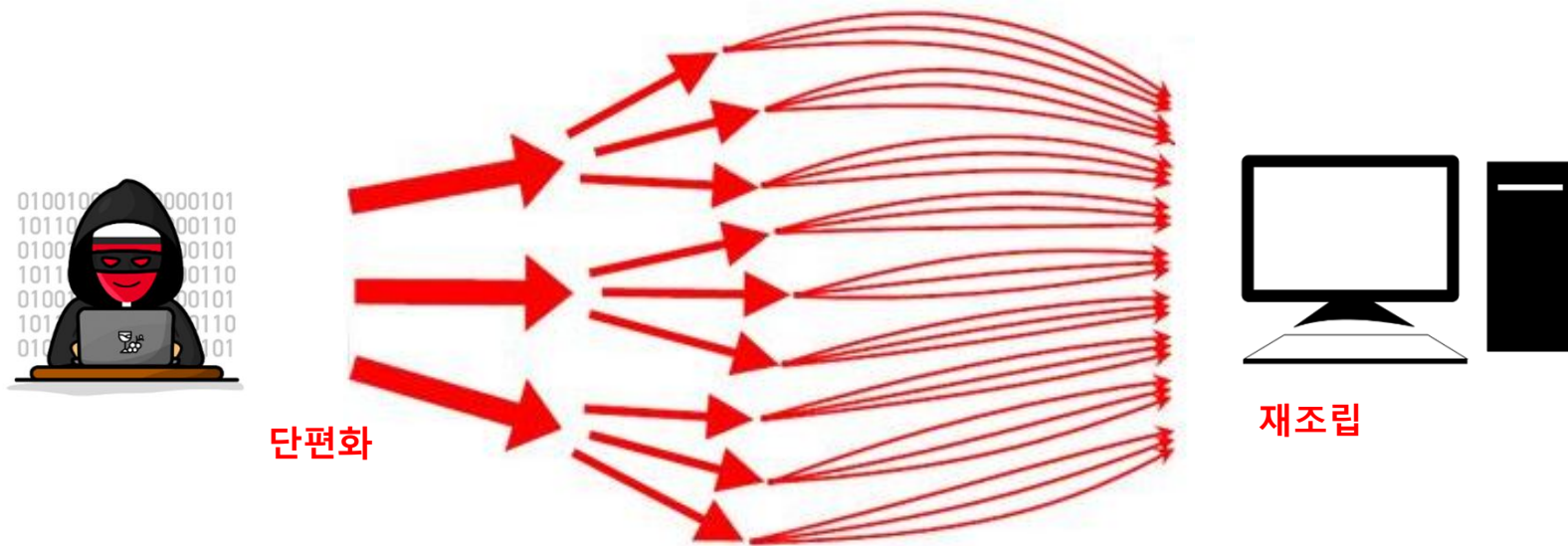
hping3 --rand-source 192.168.10.20 -p 80 -S --flood



Fragmentation Flooding Attack

* 문자열 65000 바이트로 네트워크에 ping전송

hping3 --icmp --rand-source 192.168.10.20 -d 65000 --flood



- 네트워크 기기가 전송할 수 있는 최대전송단위 MTU이상의 크기의 패킷을 전송 시, 패킷이 분할되는 단편화(fragmentation)의 특징을 이용한 공격 유형

Smurf Attack

- IP 스푸핑과 ICMP의 특성을 결합한 대표적인 증폭 반사 공격 기법
 - 증폭(Amplification): 작은 요청으로 매우 큰 응답을 유도하는 것
 - 반사(Reflection): 공격의 근원지를 찾기 매우 어렵게 만들

- 공격 명령어

hping3 --icmp --spoof [희생자_IP] --destport [포트] --flood [브로드캐스트주소]

(예) hping3 --icmp --spoof 10.10.10.10 --flood 192.168.1.255

(예) hping3 --icmp --spoof 192.168.10.20 --flood 192.168.10.255

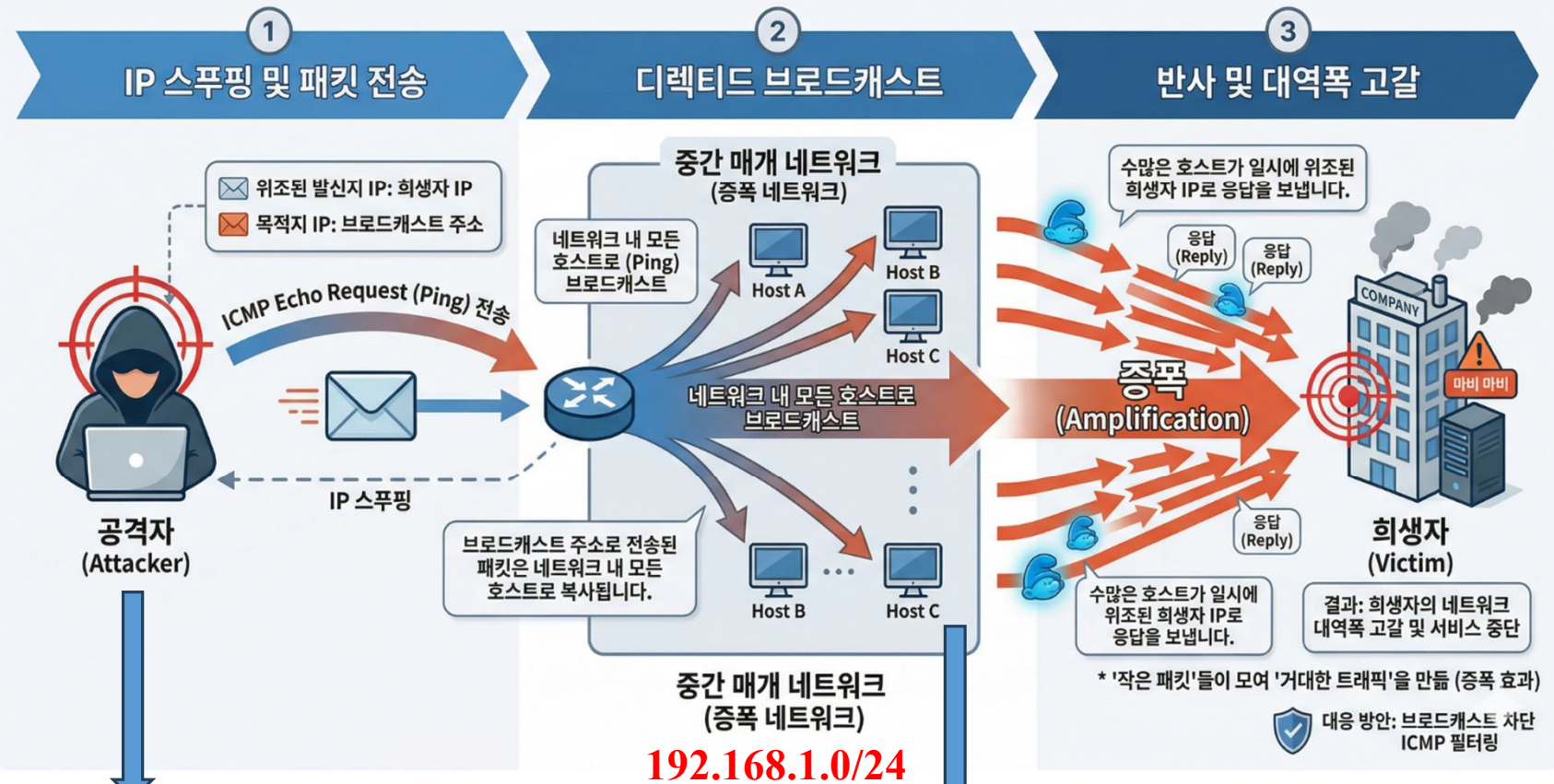
[공격 형태]

단계 1. 송신지 IP를 희생자의 IP로 위조한 패킷 생성

단계 2. 위조된 패킷을 증폭 네트워크에 ICMP Echo request 브로드캐스팅

단계 3. 증폭 네트워크 내의 다수의 호스트가 희생자에게 다량의 ICMP echo reply 전송

스머프 공격 (Smurf Attack) 작동 원리



```
tcpdump -i eth0
icmp IP 10.10.10.10 > 192.168.1.255: ICMP echo request
icmp IP 10.10.10.10 > 192.168.1.255: ICMP echo request
```

```
icmp IP 192.168.1.11 > 10.10.10.10: ICMP echo reply, id 1234
icmp IP 192.168.1.12 > 10.10.10.10: ICMP echo reply, id 1234
icmp IP 192.168.1.13 > 10.10.10.10: ICMP echo reply, id 1234
.....
```

Smurf Attack

- 대응 방안

- 1) 호스트

- Directed Broadcast 주소로 전송된 ICMP Echo-Request에 응답하지 않도록 설정

- 2) 라우터

- 브로드캐스트 패킷이 외부에서 내부로 들어오지 못하도록 설정함

Slow HTTP Header DoS Attack(Slowloris Attack)

- 공격자가 요청 헤더의 종료를 의미하는 개행문자(CRLF, 0x0d0a)를 전송하지 않음
- 연결유지를 위해 지속적으로 천천히 의미 없는 요청 헤더 정보를 전달
- 웹서버는 요청 헤더 정보를 모두 수신해야 요청 메시지 처리가능
- 모든 요청 메시지가 수신될 때 까지 연결상태를 유지하며 대기
- 공격자는 같은 방식으로 다수의 연결을 시도하여 웹서버의 연결 자원을 소진

`hping3 -S -p 80 --flood --data 100 [대상_IP]`

(예) **`hping3 -S -p 80 --flood --data 100 192.168.10.20`**

-data 옵션: 불완전한 헤더 데이터를 지속적으로 보냄

Slow HTTP Post DoS Attack(RUDY Attack)

- 요청자가 웹서버로 데이터를 전달할 때 POST 방식을 사용
- 메시지의 타입(content-type)과 크기(content-length)를 요청 헤더에 명시
- 웹서버는 요청 작업 수행 시 content-type과 content-length 참고
- 공격자는 content-length를 매우 크게 설정 후 소량의 데이터를 지속적으로 천천히 전송
- 웹서버는 content-length에 명시된 크기의 데이터를 모두 수신하기 위해 연결 유지

요청라인 POST / HTTP/1.1

요청헤더 content-type : text

content-length : 1000000000 (0x0d0a)

빈라인 0x0d0a

- 공격자는 같은 방식으로 다수의 연결을 시도하여 웹서버의 연결 자원을 소진